

Continuous Authentication Project Plan

Overview

This project transitions an offline, batch-processing User Behavior Analytics (UBA) research model into a live, enterprise-grade Zero-Trust Continuous Authentication Platform.

While traditional security systems authenticate users only once at login, this platform continuously monitors user activity throughout a session. By integrating directly with enterprise Security Information and Event Management (SIEM) systems and Identity Providers (IdPs), the system ingests authentication events asynchronously, computes real-time behavioral anomaly scores, and executes automated out-of-band session lockouts when compromised credentials or lateral movements are detected.

Current System (Research Paper)

The underlying architecture is a two-stage unsupervised machine learning pipeline designed to detect anomalies without labeled training data. It was validated offline using historical event logs from the Los Alamos National Laboratory (LANL) dataset.

- **Global Representation Learning (Undercomplete AutoEncoder):** A deep neural network that compresses system-wide behavioral attributes (e.g., host diversity, network degree centrality, temporal access) into a low-dimensional bottleneck layer. Dissimilarity from normal global system patterns is measured using Mean Squared Error reconstruction loss ($ReconError_i$).
- **User-Level Anomaly Modeling (Isolation Forest):** An ensemble tree model trained on individual user temporal habits (e.g., login frequency, average inter-event time). It isolates unusual actions that deviate from a specific user's historical baseline, producing a normalized local deviation score (s'_i).
- **Anomaly Score Fusion:** The two signals are combined using an empirically tuned weighting parameter ($\alpha = 0.5$) to generate a single continuous risk metric:

$$A_i = \alpha \times s'_i + (1 - \alpha) \times ReconError_i$$

- **Static Decision Logic:** The model establishes two operational gates based on statistical baselines:
 1. Caution Gate ($T_{95} = 0.349$): Identifies the 95th percentile of suspicious behavior.
 2. Lockout Gate ($T_{99} = 0.463$): Identifies the 99th percentile of extreme outliers representing potential attacks.

Functional Requirements

1. Enterprise Onboarding & Anonymization

- **Tenant & Enterprise Metadata Provisioning:** Administrators must be able to register their organization, manage enterprise-specific configurations (such as IdP client IDs and custom alert rules), and generate secure ingestion endpoints. This enterprise data will be structured and stored directly in PostgreSQL.
- **Zero-Touch Log Forwarding:** The platform must ingest standard, unmodified enterprise log formats (Syslog, JSON) without requiring client-side scripts or data pre-processing.
- **In-Memory Anonymization:** The Ingestion API Gateway must perform real-time cryptographic hashing (SHA-256 with a tenant-specific salt managed via a KMS) of all usernames and IP addresses strictly in volatile memory.
- **Zero-PII Persistence:** The system must enforce a strict drop-policy for raw identifiers; no unhashed user data may be written to message brokers, databases, or application logs, while still ensuring consistent hash generation to model individual user deviation via the Isolation Forest.

2. Data Ingestion & PostgreSQL

- **FastAPI Background Tasks:** The ingestion endpoint must utilize native asynchronous background thread pools (`BackgroundTasks`) to process logs without blocking incoming SIEM webhooks.
- **Unified PostgreSQL Storage:** Store all anonymized event logs, calculated anomaly scores, and enterprise metadata in PostgreSQL.
- **Indexed Time-Series Feature Extraction:** Asynchronous workers must execute optimized SQL window queries over indexed (`user_hash`, `timestamp`) database columns to dynamically compute real-time temporal habits (`login_frequency`, `avg_inter_event_time`) in milliseconds.

3. ML Inference & Baselineing

- **Parallel Scoring:** The machine learning engine must concurrently evaluate the live feature vector against the global AutoEncoder and local Isolation Forest models.
- **Score Fusion:** Calculate the consolidated anomaly index (A_i) on the fly.
- **Shadow Mode:** Provide a read-only training phase where the system logs scores and learns baselines without triggering active lockouts.

4. Automated Out-of-Band Enforcement

- **IdP Session Termination:** When an event breaches the lockout threshold ($A_i \geq 0.463$), the backend must trigger an authenticated REST API call to the enterprise Identity Provider (e.g., Okta, Entra ID) to instantly revoke JSON Web Tokens (JWTs) and terminate Single Sign-On (SSO) sessions.
- **Step-Up MFA Challenge:** When an event enters the caution zone ($0.349 \leq A_i < 0.463$), the platform must instruct the IdP to issue a non-disruptive Multi-Factor Authentication prompt.
- **Bi-Directional Alerting:** All enforcement actions and anomaly scores must be pushed back into the enterprise SIEM to generate high-priority incident tickets automatically.

5. SOC Administrative Dashboard

- **Live Threat Feed:** A real-time log displaying processed authentication events fetched from PostgreSQL, color-coded by risk severity.
- **Bivariate Conflict Zone Visualizer:** An interactive 2D scatter plot mapping users across Global Reconstruction Error vs. Local Anomaly Score to separate identity deviance from systemic deviance.
- **Explainable AI (XAI):** A diagnostic view that calculates feature-level residuals ($|x_i - \hat{x}_i|$) to show analysts the exact metrics driving a lockout decision.
- **Hyperparameter Control:** UI sliders allowing administrators to dynamically adjust the weighting factor α and customize threshold percentiles.

Implementation Plan

Phase 1 - Foundation, Ingestion & PostgreSQL Setup

- Design and deploy the relational **PostgreSQL** database schemas for enterprise tenant metadata, IdP configurations, and anonymized authentication logs.
- Develop the FastAPI ingestion endpoint with API key authentication and the volatile in-memory salted-hash anonymization middleware.
- Implement native `BackgroundTasks` routing to accept incoming SIEM webhooks asynchronously.

Phase 2 - ML Engine & SQL Feature Pipeline

- Containerize the PyTorch AutoEncoder and Scikit-Learn Isolation Forest models.

- Write optimized PostgreSQL window queries to extract global metrics (`unique_hosts` , network centrality) and user temporal habits (`login_frequency` , `avg_inter_event_time`) directly from the database tables.
- Build the mathematical score fusion (A_i) pipeline and save output evaluation records back to PostgreSQL.

Phase 3 - Out-of-Band IdP Integration & Workflows

- Build OAuth 2.0 API integrations for major IdPs (Okta and Microsoft Entra ID), storing encrypted access tokens in PostgreSQL.
- Write the automated response logic: trigger MFA webhooks for Caution scores ($A_i \geq 0.349$) and session kill-switches for Lockout scores ($A_i \geq 0.463$).
- Develop the reverse-webhook mechanism to push structured incident payloads back to the client's SIEM.

Phase 4 - SOC Admin Dashboard & XAI Visualization

- Develop the dashboard UI and integrate with the backend.
- Build the XAI residual breakdown engine to generate human-readable explanations for every blocked event.
- Add admin controls for the α -weighting parameter and threshold calibration.

Phase 5 - Testing and Validation

- Run end-to-end load testing using simulated SIEM log streams to verify that PostgreSQL indexing and background tasks maintain sub-second inference latency.
- Execute "Shadow Mode" testing against synthetic attack vectors (credential stuffing, lateral movement) to measure False Positive Rates (FPR).
- Package the entire deployment (FastAPI, PostgreSQL, Next.js) using Docker Compose for simple evaluator setup.